

BEFORE Placeholder

AFTER

Vulnerability Management Control Baseline (Tiered)

Document classification: Internal

Baseline owner: Security Engineering/Architecture

Version: 0.1

Effective date: _____

Review cadence: Annually

1. Purpose

Define minimum vulnerability management controls for third parties, including scanning/testing expectations, remediation timelines, disclosure/communication requirements, and validation steps.

2. Scope

Applies to suppliers that:

- provide SaaS/services that process organisational data, and/or
- integrate into organisational systems (API/agent/connectivity), and/or
- host applications/infrastructure used by the organisation, and/or
- have privileged access or production influence.

3. Control statements (tiered)

3.1 Tier Critical (Tier 1) — MUST controls

Critical suppliers MUST:

1. Maintain a documented vulnerability management process covering identification, triage, remediation, and verification.
2. Perform vulnerability assessment activities appropriate to the service (e.g., scanning, code/dependency scanning for SaaS/software).
3. Remediate vulnerabilities in timeframes appropriate to risk and service criticality, or provide mitigations and a remediation plan.
4. Provide independent security testing evidence appropriate to the service (executive summary acceptable) within the last 12 months.
5. Maintain a vulnerability disclosure/communication mechanism to inform customers of material issues affecting service scope.
6. Provide a remediation status update for high-risk findings relevant to the service.

Critical suppliers SHOULD:

- run continuous or frequent scanning (as applicable) for exposed services
- implement dependency/SBOM management for software components
- provide customer-relevant remediation guidance and compensating controls during active exploitation events

3.2 Tier Important (Tier 2) — MUST controls

Important suppliers MUST:

- maintain a documented vulnerability management and patching process
- provide a statement of remediation approach and typical timelines
- provide appropriate testing/assurance evidence (pen test summary, audit summary, or equivalent) proportionate to service

Important suppliers SHOULD:

- provide independent testing evidence within the last 24 months (or per internal standard)
- provide a security contact and disclosure channel for vulnerabilities

3.3 Tier Low (Tier 3) — proportionate controls

Low suppliers SHOULD:

- confirm they maintain basic patching and vulnerability management practices
- provide a public security statement or lightweight assurance evidence on request

4. Minimum requirements by control area

4.1 Vulnerability identification

MUST:

- Define how vulnerabilities are identified across:
 - infrastructure/platform (if applicable)
 - applications/services
 - dependencies/third-party libraries (if software/SaaS)
 - configuration baselines and cloud settings (where applicable)

SHOULD:

- Include external attack surface considerations for internet-facing services.

4.2 Triage and severity

MUST:

- Have a severity model (e.g., critical/high/medium/low) and triage process.
- Prioritise vulnerabilities exploitable in the wild and those affecting privileged access, authentication, and sensitive data paths.

4.3 Remediation and patching

MUST:

- Have defined remediation timelines or an equivalent risk-based approach.
- Provide mitigations if remediation cannot meet timelines.

Guidance (to be tailored to internal standards; do not treat as universal):

- Critical vulnerabilities: target remediation within days/weeks, depending on exposure
- High vulnerabilities: target remediation within weeks
- Medium/Low: risk-based scheduling

MUST (Critical suppliers):

- communicate delays for high-risk vulnerabilities affecting customer scope, with mitigation steps.

4.4 Verification

MUST:

- Verify remediation (re-scan, retest, or validation steps) and record closure.

4.5 Security testing (independent assurance)

MUST (Critical suppliers, service-appropriate):

- Provide at least one of:
 - pen test executive summary (last 12 months)
 - SOC/ISO audit outputs relevant to vulnerability management controls
 - other independent assurance evidence (if pen test is not applicable)

SHOULD:

- Provide remediation status for high/critical findings (open/closed, target dates).

4.6 Disclosure and customer communication

MUST (Critical/Important suppliers):

- Provide a security contact or disclosure channel.
- Provide notification to customers for material vulnerabilities affecting the service scope, where practical and appropriate.

SHOULD:

- Provide customer impact statements and recommended mitigations during active exploitation.

5. Validation steps (how to prove it)

For each supplier, capture evidence and complete checks.

5.1 Process evidence

☐ Vulnerability management process documented (policy/process summary)

☐ Severity model and triage approach described

Evidence location:

5.2 Remediation evidence

☐ Patch/remediation approach and typical timelines described

☐ Example remediation tracking evidence (redacted) OR statement of tracking method

Evidence location:

5.3 Testing evidence

☐ Independent testing evidence provided (executive summary acceptable)

☐ High/critical findings remediation status provided (where applicable)

Evidence location:

5.4 Disclosure and comms

☐ Security contact/disclosure channel provided

☐ Customer notification approach for material issues described

Evidence location:

6. Exceptions

Where a Critical supplier cannot provide appropriate assurance/testing evidence, an exception MUST:

- document why evidence is unavailable
- define alternative assurance evidence
- add compensating controls (e.g., tighter access, reduced scope, enhanced monitoring)
- include expiry date and a plan to obtain appropriate assurance

7. Sign-off (per supplier)

Supplier: _____ Service: _____ Tier: ☐ Critical ☐
Important ☐ Low

Security Engineering/Architecture (role title): _____ Date: _____ Business Service
Owner (role title): _____ Date: _____ Procurement (role title, if required):
_____ Date: _____